

Siber Güvenlik Mühendisliği Eğitimi - 2026
201 MALWARE OPERASYONU: "The Malware
Hunter"
Betül ALTAY
05.05.2026

FAZ 1: Mimari ve Temeller (Research & Logic)

1. Analiz Türleri: "Durağan ve Hareketli"

Statik Analiz (dosyayı çalıştırmadan incelemek) ile **Dinamik Analiz** (dosyayı çalıştırarak izlemek) arasındaki fark nedir? Neden dinamik analiz yapmadan önce mutlaka statik analiz yapmalıyız?

- Statik analiz dosyayı çalıştırmadan inceler. Dinamik analiz ise dosyayı sanal makinede çalıştırıp davranışını izler. Önce statik yapmalıyız çünkü dinamik analiz risklidir; dosya hakkında önceden bilgi sahibi olmadan çalıştırmak sisteme zarar verebilir.

2. Güvenli Alan: "Kafes (Sandbox)"

Sandbox (Kum Havuzu) nedir? Şüpheli bir dosyayı neden kendi ana işletim sistemimizde (Host) değil de ağdan izole edilmiş bir sanal makinede (Guest) inceleriz?

- Sandbox, şüpheli dosyaları güvenli bir şekilde çalıştırıp inceleyebileceğimiz, ana sistemden izole edilmiş bir test ortamıdır. Çünkü dosya gerçekten zararlıysa bilgisayarımıza bulaşır, dosyalarımızı şifreleyebilir veya ağdaki diğer cihazlara yayılabilir. Sanal makine ağdan izole olduğu için zararlı yazılım dışarı çıkamaz.

3. Tersine Mühendislik (Reverse Engineering): "Kodu Geriye Sarmak"

Tersine mühendislik nedir? Sadece makine dilinden (1 ve 0'lar) veya Assembly dilinden ibaret olan derlenmiş (compiled) bir .exe dosyasını analiz etmek, bize o yazılımın "niyeti" hakkında nasıl ipuçları verir?

- Tersine mühendislik, kaynak kodu elimizde olmayan bir programı sökerek nasıl çalıştığını anlamaya çalışmaktır. Dosyanın içindeki string'lere bakınca IP adresi, web sitesi veya tuhaf mesajlar görebiliriz. Kullandığı fonksiyonlara bakınca da niyetini anlarız; mesela dosya şifreleme fonksiyonları çağırıyorsa fidye yazılımı, klavye dinleme fonksiyonları varsa keylogger olduğunu düşünebiliriz.

FAZ 2: Saha Operasyonu (Boss Fights)

Cephe 1: Dosyayı Kesip Biçmek (Basic Static Analysis)

3. adım : Ekli VM'deki Masaüstünde, 1'den 6'ya kadar kötü amaçlı yazılım örnekleri içeren 'mal' adlı bir dizin vardır. 2, 5 ve 6 adlı örneklerde bulunan gizlenmiş dizeleri tanımlamak için dış ipi kullanın. Bu örneklerden hangisi 'DbgView.exe' dizesini içerir?

bu adım için öncelikle terminali açtım ve floss yüklü mü kontrol ettim

```
C:\Users\Administrator>floss --version
floss.exe 1.7.0-alpha1
https://github.com/fireeye/flare-floss/

FLARE Tue 05/05/2026 10:20:54.58
C:\Users\Administrator>
```

çiktisiyla floosun olduğunu anladım ve terminalde kontrol ettiğimde

[illegible]

6. dosyanın içinde Dbgview.exe olduğu belli oldu

cevap 6

4. adım / A : Ekteki VM'deki Desktop\mal\ dizininde bulunan örneklerde, örneklerden hangisinin dosya 3 ile aynı imphash'i var?

Önce 3 numaralı dosyanın imphash'ini aldım

```
FLARE Tue 05/05/2026 10:28:00.34
C:\Users\Administrator\Desktop\mal>python -c "import pefile; pe=pefile.PE('3'); print(pe.get_imphash())"
f40e8f975cf118eadd4d99d120d05f77
f40e8f975cf118eadd4d99d120d05f77
```

sonrasında sırasıyla diğer dosyalara da aynı işlemi gerçekleştirdim ve 1. ile aynı olduğunu gördüm

```
FLARE Tue 05/05/2026 10:28:00.34
C:\Users\Administrator\Desktop\mal>python -c "import pefile; pe=pefile.PE('3'); print(pe.get_imphash())"
f40e8f975cf118eadd4d99d120d05f77

FLARE Tue 05/05/2026 10:31:36.27
C:\Users\Administrator\Desktop\mal>python -c "import pefile; pe=pefile.PE('1'); print(pe.get_imphash())"
f40e8f975cf118eadd4d99d120d05f77
```

cevap 1

4. adım / B : Ssdeep yardımcı programını kullanarak, yukarıda belirtilen dosyaların yüzde eşleşmesi nedir?

5. adım / A : Örnekte anti-VM yürütme teknikleri için kaç eşleşme belirlendi?

Öncelikle capa 4 | findstr /i "anti-vm" sorgusuyla capa/yı çalıştırıp 4. dosyada anti-vm araması yaptım. Aşağıdaki çıktıyı aldım

```
FLARE Tue 05/05/2026 10:47:02.01
C:\Users\Administrator\Desktop\mal>capa 4 | findstr /i "anti-vm"
loading : 100% | 485/485 [00:00<00:00, 1619.33 rules/s]
matching: 100% | 7123/7123 [01:39<00:00, 71.52 functions/s]
| check for unmoving mouse cursor | anti-analysis/anti-vm/vm-detection
| execute anti-VM instructions (86 matches) | anti-analysis/anti-vm/vm-detection
F
FLARE Tue 05/05/2026 10:50:12.92
C:\Users\Administrator\Desktop\mal>_
```

cevap da buradan 86 çıkmış oluyor

5. adım / B : Numunenin bir iş parçacığını askıya alma veya devam ettirme yeteneği var mı? Evet için Y ve hayır için N ile cevap verin.

Öncelikle capa 4 | findstr /i "thread" filtresi ile sorgulama yaptım. suspend thread veya resume thread ile ilgili bir şey arıyoruz.

```
FLARE Tue 05/05/2026 10:50:12.92
C:\Users\Administrator\Desktop\mal>capa 4 | findstr /i "thread"
loading : 100% | 485/485 [00:00<00:00, 1938.15 rules/s]
matching: 100% | 7123/7123 [01:42<00:00, 69.21 functions/s]
| PROCESS | Allocate Thread Local Storage [C0040]
| | Create Thread [C0038]
| | Resume Thread [C0054]
| | Set Thread Local Storage Value [C0041]
| | Suspend Thread [C0055]
| get thread local storage value (7 matches) | host-interaction/process
| set thread local storage value (6 matches) | host-interaction/process
| create thread | host-interaction/thread/create
| resume thread (2 matches) | host-interaction/thread/resume
| suspend thread | host-interaction/thread/suspend
F
FLARE Tue 05/05/2026 10:54:16.45
C:\Users\Administrator\Desktop\mal>_
```

Çıktıda hem Resume Thread hem de Suspend Thread açıkça görünüyor
cevap Y

5. adım / C : MBC Objective 'Anti-Statik Analiz' e karşı hangi MBC davranışı gözlemleniyor?

capa çıktısındaki MBC tablosuna bakacağız. capa 4 | findstr /i "anti-static" filtresini kullanıyoruz

```
FLARE Tue 05/05/2026 10:50:12.92
C:\Users\Administrator\Desktop\mal>capa 4 | findstr /i "thread"
loading : 100% [redacted] 485/485 [00:00<00:00, 1938.15 rules/s]
matching: 100% [redacted] 7123/7123 [01:42<00:00, 69.21 functions/s]
| PROCESS |
| |
| | Allocate Thread Local Storage [C0040]
| |
| | Create Thread [C0038]
| |
| | Resume Thread [C0054]
| |
| | Set Thread Local Storage Value [C0041]
| |
| | Suspend Thread [C0055]
| |
| get thread local storage value (7 matches) | host-interaction/process
| set thread local storage value (6 matches) | host-interaction/process
| create thread | host-interaction/thread/create
| resume thread (2 matches) | host-interaction/thread/resume
| suspend thread | host-interaction/thread/suspend
|
FLARE Tue 05/05/2026 10:54:16.45
C:\Users\Administrator\Desktop\mal>capa 4 | findstr /i "anti-static"
loading : 100% [redacted] 485/485 [00:00<00:00, 1826.31 rules/s]
matching: 100% [redacted] 7123/7123 [01:42<00:00, 69.49 functions/s]
| ANTI-STATIC ANALYSIS | Disassembler Evasion::Argument Obfuscation [B0012.001]
```

Çıktının en alt satırında cevap görünüyor: Disassembler Evasion::Argument Obfuscation [B0012.001]

6. adım / A : PEstudio'da örnek Desktop\mal\4'ü açın. Hangi kütüphane kara listeye alınmıştır?
Pestudio'da 4. dosyayı çalıştırdım ve kütüphaneye girip kara listede olanı buldum

rpcrt4.dll	x	implicit	1	Remote Procedure
------------	---	----------	---	------------------

Cevap rpcrt4.dll

6. adım / B : Bu dll ne işe yarıyor?

rpcrt4.dll, Windows'un Remote Procedure Call (uzak prosedür çağrısı) işlemlerini yöneten bir kütüphanesidir. Programların aynı sistemde veya ağ üzerindeki başka sistemlerde bulunan fonksiyonları çağırmasını sağlar.

Cevap Remote Procedure Call Runtime

Cephe 3: Malware Hunter (Boss Fight: MalBuster)

2. adım / A : Based on the ARCHITECTURE of the binary, is malbuster_1 a 32-bit or a 64-bit application? (32-bit/64-bit)

```
ubuntu@ip-10-114-152-112:~/Desktop/Samples$ file malbuster_1
malbuster_1: PE32 executable (GUI) Intel 80386, for MS Windows
```

32-bit

2. adım / B : What is the MD5 hash of malbuster_1?

Bu sefer md5sum komutunu kullandık

```
ubuntu@ip-10-114-152-112:~/Desktop/Samples$ md5sum malbuster_1
4348da65e4aeae6472c7f97d6dd8ad8f  malbuster_1
```

4348da65e4aeae6472c7f97d6dd8ad8f

2. adım / C : Using the hash, what is the popular threat label of malbuster_1 according to VirusTotal?

Virustotal'de hash'ini kontrol ettim

Popular threat label ⓘ trojan.zbot/razy

2. adım / D : Based on VirusTotal detection, what is the malware signature of malbuster_2 according to Avira?

malbuster_2'nin hash'ini aldık

```
ubuntu@ip-10-114-152-112:~/Desktop/Samples$ md5sum malbuster_2
1d7ebed1baece67a31ce0a17a0320cb2  malbuster_2
```

hash'i virustotal'de sorguladık ve cevaba ulaştım

Avira (no cloud)



HEUR/AGEN.1306860

2. adım / E : malbuster_2 imports the function _CorExeMain. From which DLL file does it import this function?

strings malbuster_2 | grep -i ".dll" parametresi ile sorgu yaptım

```
ubuntu@ip-10-114-152-112:~/Desktop/Samples$ strings malbuster_2 | grep -i "\.dll"
"
mscoree.dll
```

2. adım / F : Based on the VS_VERSION_INFO header, what is the original name of malbuster_2?

```
ubuntu@ip-10-114-152-112:~/Desktop/Samples$ strings -e l malbuster_2 | grep -i ".exe"
.exe"
7JYpE.exe
7JYpE.exe
```

2. adım / G : Using the hash of malbuster_3, what is its malware signature based on abuse.ch?

malbuster_3 'ün hash'ini malware'de sorguladım ve cevap çıktı

Date (UTC)	SHA256 hash	Type	Signature	Tags	Reporter	DL
2021-07-22 17:12	9da8a5a0b5957db6112e...	dll	TrickBot	dll rob109 TrickBot	abuse_ch	

2. adım / H : Using the hash of malbuster_4, what is its malware signature based on abuse.ch?

Üstteki adımların aynısını yaptım sadece URL ile sorguladım ve sonuç çıktısındaki



2. `adim / I : malbuster_4` imports the function `ShellExecuteA`. From which DLL file does it import this function?

```
ubuntu@ip-10-114-152-112:~/Desktop/Samples$ strings malbuster_4 | grep -i "shell
32"
shell32.dll
```

2. adım / J : Using capa, which binary can log keystrokes?

Sırayla malbuster'ları sorguladım ve cevabı buldum

2. adım / K : Using capa, what is the MITRE ID of the DISCOVERY technique used by malbuster 4?

Çıktıyı filtreledim ve sonucu buldum

2. `adım / L` : Which binary contains the string `GodMode`?

FAZ 3: Mühendislik Vizyonu ve Tehdit Sözlüğü (Conclusion)

1. Assembly Diline Girls:

Tersine mühendislik yaparken sıkça gördüğümüz makine dili (Assembly)

komutlarından MOV EAX, 1 komutu temel mantıkta ne anlama gelir? Neden bu dili okuyabilmek ileri seviye analiz için kritiktir?

- MOV EAX, 1 komutu aslında "EAX denilen yere 1 yaz" demekmiş. EAX da işlemcinin içindeki ufak bir kutu gibi bir şey, register deniyormuş. Yani çok basit bir işlem, bir değişkene değer atamak gibi.

Bu dili okumak önemli çünkü zararlı dosyaların kaynak kodu bizde olmuyor. Diğer araçlar bir yere kadar bilgi veriyor ama programın gerçekten ne yaptığını derinlemesine anlamak için Assembly'ye bakmak gerekiyor. Yoksa bazı şeyleri kaçırabiliyoruz.

2. Hayatta Kalma Sanatı (Persistence):

Bir virüs, bilgisayar yeniden başlatıldığında (Restart) silinmemek ve tekrar aktif olmak için kendini Windows işletim sisteminde nerelere gizler? (Kayıt Defteri/Registry ve Startup klasörü mantığını açıklayın).

- Virüsler bilgisayar kapanıp açıldığında silinmemek için kendilerini iki yere gizliyorlarmış. Birincisi Registry. Windows'un içinde "Run" diye bir yer var, oraya yazılan programlar bilgisayar her açıldığında otomatik çalışıyor. Virüs de kendini oraya ekliyor. İkincisi Startup klasörü. Bu klasöre konan dosyalar açılışa otomatik çalışıyor. Virüs de kendini buraya kopyalayarak her başlangıçta tekrar aktif oluyor.

3. Kukla Ustası (Command & Control - C&C):

Zombi (enfekte olmuş) bir bilgisayar, dışarıdaki asıl saldırgandan (Hacker) nasıl komut alır? C&C sunucusu mantığı nedir ve biz bunu ağ trafiğinde (Wireshark) nasıl yakalarız?

- Zombi bilgisayar, virüs bulaşmış ve saldırganın emirlerini bekleyen bir bilgisayar. Saldırgan komutları C&C sunucusu (Command and Control) üzerinden gönderiyor. Yani zombi bilgisayar belirli aralıklarla bu sunucuya bağlanıp "yeni emir var mı" diye soruyor, sunucu da emri veriyor. Wireshark ile bu trafiği yakalayabiliyoruz. Bilgisayar sürekli aynı tuhaf adrese paket gönderiyorsa orası büyük ihtimalle C&C sunucusudur.

4. Hayalet Tehditler (Fileless Malware):

Geleneksel antivirüsler diske yazılan dosyaları (.exe) tarar. Peki "Dosyasız Zararlı Yazılım" (Fileless Malware) diske hiçbir dosya kaydetmiyorsa, sistemin neresinde yaşar ve komutlarını nasıl çalıştırır? (Örn: RAM, PowerShell).

Dosyasız zararlı yazılım, diske .exe gibi bir dosya kaydetmiyormuş. Bu yüzden antivirüsler yakalamakta zorlanıyor.

Bunun yerine bilgisayarın **RAM**'inde yani geçici hafızasında çalışıyor. Komutlarını da Windows'ta zaten yüklü olan **PowerShell** gibi araçları kullanarak veriyor. Böylece sisteme yabancı bir program girmediği için antivirüse normal bir işlem gibi görünüyor.